RISK MANAGEMENT ASSESSMENT: Toyota Motor Manufacturing Kentucky (TMMK) RAV4 HYBRID

SIE 573 Systems Engineering

TEAM 5

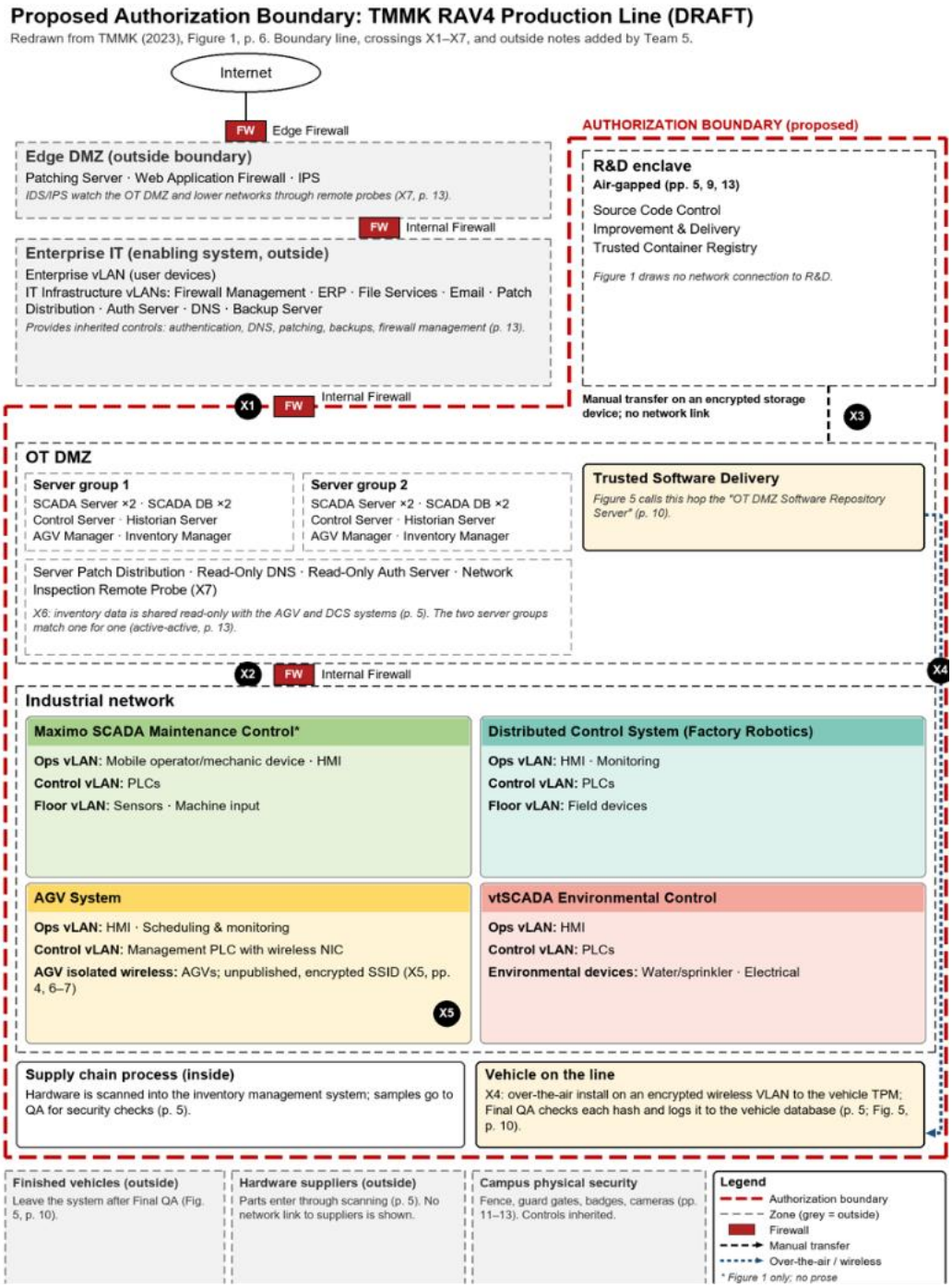
Bhanuprakash Kandimalla
Mukwaya Lwere
Desiree O'Cleireachain
Samuel Yoon

1. Security Categorization & Impact Matrix

- **Confidentiality Potential Impact (MODERATE Impact):** The unauthorized disclosure of information could be expected to have a serious adverse effect on organizational operations, organizational assets, or individuals.
    - Human error or public-facing database misconfigurations risk exposing unique Vehicle Identification Numbers (VINs), navigation terminal locations, and onboard video footage of over 2 million vehicle users (as seen in the 2012–2023 cloud leak).
- **Integrity Potential Impact (MODERATE Impact):** The unauthorized modification or destruction of information could be expected to have a severe or catastrophic adverse effect on organizational operations, organizational assets, or individuals.
    - Software integrity is directly linked to physical safety under ISO 26262 lifecycle rules. Altered or manipulated firmware flashed into a Toyota Safety Sense 2.0 leaves the plant inside a customer's car, creating a catastrophic hazard on public roads.
- **Availability Potential Impact: (MODERATE Impact)**: The disruption of access to or use of information or an information system could be expected to have a severe or catastrophic adverse effect on organizational operations, organizational assets, or individuals.
    - Toyota Motor Manufacturing Kentucky's (TMMK) Just-in-Time (JIT) manufacturing model leaves zero fault tolerance for downtime. As demonstrated by the 2022 Kojima Industries ransomware attack, severing the Electronic Data Interchange (EDI) infrastructure forces the immediate shutdown of production lines, halting thousands of vehicles a day.
- **Overall System Impact Level: MODERATE IMPACT** (Governed by the NIST "high-water mark" principle, where the overall system baseline matches the highest individual objective rating).

1.1 System Boundary

The authorization boundary sets the scope of what the organization agrees to protect as one system, and the Authorizing Official approves it (NIST, 2018, p. 38). The team proposes the scope the TMMK architecture document gives itself: the manufacturing line, R&D and software delivery, and the supply chain (TMMK, 2023, p.2). Figure A shows the proposed boundary, and Appendix A lists each component with its source page.



Inside the boundary: the R&D enclave, the OT DMZ, the four industrial subsystems (Maximo SCADA Maintenance Control, the Distributed Control System, the AGV System, and vtSCADA Environmental Control), both internal firewalls, and the supply chain and Final QA processes. **Outside:** Enterprise IT, treated as an enabling system that supplies inherited controls such as authentication, DNS, patching, and backups (NIST, 2018, p. 15; TMMK, 2023, p. 13); the Edge DMZ and Internet; campus physical security; finished vehicles; and hardware suppliers.

Boundary crossings, where the controls in Section 4 apply:

ID	Crossing	How it works in the TMMK document	Source
X1	Enterprise IT ↔ OT DMZ	Internal firewall; whitelist ACLs allow only explicitly defined traffic.	TMMK, 2023, pp. 4, 6, 13
X2	OT DMZ ↔ industrial network	Internal firewall between the OT DMZ servers and the plant floor.	TMMK, 2023, pp. 6, 8–9
X3	R&D → Trusted Software Delivery	No network link. Software moves by hand on dedicated encrypted storage devices, which are wiped and checked before returning to R&D.	TMMK, 2023, pp. 5, 9, 13
X4	Trusted Software Delivery → vehicle TPM	Over-the-air install on an encrypted wireless VLAN, then the Final QA hash check.	TMMK, 2023, pp. 5, 10
X5	AGV management → AGVs	Wireless on an unpublished, encrypted SSID used only by the AGV system.	TMMK, 2023, pp. 4, 6–7
X6	Inventory management → AGV and DCS	Data shared read-only.	TMMK, 2023, p. 5
X7	Edge DMZ IDS/IPS → OT DMZ and lower networks	Remote network probes.	TMMK, 2023, p. 13

2. Process Phase, Task, & Accountability Matrix

The following matrix displays the specific timeframe, technical tasks, deliverables assigned, team roles, and the governing standards utilized for each phase.

RMF Phase	Timeframe	Team Action Items / Tasks	Required Deliverables	Team Roles Assigned	Governing Policies & Standards
Phase 1: Prepare and Categorize	**1 Week**	Task 1: Define Mission Statement, Objective and Goals Task 2: Assign Roles and Responsibilties Task 3: Map the physical and logical boundaries of the RAV4 assembly line. Task 4: Analyze the IT/OT convergence layers (Enterprise IT → OT DMZ → Ops VLAN → Control VLAN → Floor VLAN).	Deliverable 1: System Boundary Network Topology Diagram Deliverable 2: FIPS 199 Security Categorization Report	Systems Security Engineer OT Network & Security Engineer Legal & Standards Consultant	NIST SP 800-37 R2, NIST SP 800-60, FIPS 199

RMF Phase	Timeframe	Team Action Items / Tasks	Required Deliverables	Team Roles Assigned	Governing Policies & Standards
Phase 2: Control Selection	**Week 5**	Task 1: Idenify controls using baseline selection controls to address the needs of TMMK. Task 2: Tailor selected controls to TMMK and the specific threats identified on the Threat Matrix	Controls selected for the system and the environment of operation (baseline or oganization-generated), List of tailored controls for the system and environment of operation (i.e., tailored control baselines). List of security and privacy controls allocated to the system, system elements, and the environment of operation. Security and privacy plans for the system. Continuous monitoring strategy for the system including time-based trigger for ongoing authorization. Security and privacy plans approved by the authorizing official.	Systems Security Engineer OT Network & Security Engineer , QA Engineer	NIST SP 800-82 R2, NIST SP 800-53 R5, NIST SP 800-53B
Phase 3: Implementation	**Week 6**	Document how each control is deployed. Describe physical, technical, and operational configurations. Define specific hardware trust anchors. (Task -I1, Task -I2)	Controls specified in the security and privacy plans are implemented. Security and privacy plans updated with implementation detail sufficient for use by assessors; system configuration baseline.	Systems Security Engineer OT Network & Security Engineer	FIPS 200, SP 800-30, SP 800-53, SP 800-53A, SP 800-160 v1

RMF Phase	Timeframe	Team Action Items / Tasks	Required Deliverables	Team Roles Assigned	Governing Policies & Standards
Phase 4: Assessment	**Weeks 6-7 (concurrent w/ Implementation)**	Develop security control test plans. Execute vulnerability scans and penetration tests. Verify that implemented controls function correctly.	Produce the Security Assessment Report (SAR). List all active or unresolved vulnerabilities.	QA Engineer	NIST SP 800-53A, NIST SP 800-30
Phase 5: Authorization	**Week 7**	Review final system risk posture. Determine if residual risks are acceptable. Outline remediation plans for remaining vulnerabilities.	Complete the Plan of Action & Milestones (POA&M). Produce the formal Authorization to Operate (ATO).	Legal & Standards Consultant	SP 800-160 v1
Phase 6: Continuous Monitoring	**Ongoing**	Define continuous monitoring scan frequencies. Establish automated log analysis rules. Track third-party vendor patch updates.	Write the Continuous Monitoring Strategy. Produce monthly vulnerability tracking reports.	Systems Security Engineer OT Network & Security Engineer	SP 800-30, SP 800-53, SP 800-53A, SP 800-137, SP 800-160 v1

3. Threat Modeling & Cyber-Physical Risk Register

To systematically evaluate the attack surface of the Toyota Motor Manufacturing Kentucky (TMMK) RAV4 Hybrid production infrastructure, this risk assessment bridges systemic digital vulnerabilities directly to physical consumer functional safety requirements under ISO 26262. Operating within a converged IT/OT environment implies that software delivery pipelines and operational technology layers are no longer isolated; a compromise at a single digital entry point can yield catastrophic physical failure modes on the factory floor or result in the deployment of defective vehicles.

Following the structured guidelines of NIST SP 800-30 Rev. 1, this Threat Modeling and Cyber-Physical Risk Register analyzes adversarial vectors across both insider and outsider threat spectrums. Each identified threat vector is categorized by its corresponding layer within the Purdue Model hierarchy, mapping specific system vulnerabilities to historical sector precedents, such as the 2022 Kojima Industries supply chain disruption and the foundational paradigm of Stuxnet-style logic manipulation. By evaluating these risks through a qualitative 5x5 matrix scoring mechanism (measuring Likelihood and Impact from 1 to 5), the team establishes the critical, unmitigated baseline risk profile. This technical mapping provides the necessary data-driven

foundation required to justify the selection, allocation, and deployment of modern cyber resiliency engineering controls within the final System Security Plan (SSP).

Risk ID	Threat Event & Vulnerability / Vector	Targeted Purdue Layer & System Component	Threat Actor Profile	Real-World Engineering Consequence	Risk Level
R-01	JIT Supply-Chain Infrastructure Freeze via malware encryption of shared network dependencies.	Enterprise IT --> External Supplier EDI Gateways	Outsider (Cyber criminals)	Severance of parts-sequencing databases forcing catastrophic plant-wide production halts (2022 Kojima Industries attack vector).	**HIGH**
R-02	Air-Gap Tampering & Stuxnet-Style Payload via unverified physical media.	R&D Air Gap --> OT DMZ Software Server	Insider, or outsider via compromised media	Unauthorized code execution within the software delivery server without verifying signatures or checking file integrity.	**HIGH**
R-03	Unauthenticated PLC Logic Manipulation overriding safety limits via legacy industrial frameworks.	Control VLAN -> Floor VLAN (PLCs & DCS)	Insider	Manipulation of low-level mechanical loop programming to induce physical damage or inject latent structural defects.	**HIGH**
R-04	CAN Bus Layer Exploitation via exposed exterior component physical interfaces.	Floor VLAN --> Vehicle Electronic Control Unit (ECU) (outside the plant boundary: attack on a sold vehicle)	Outsider (Adversary)	Splice-injection via exterior harnesses (CVE-2023-29389 Headlight CAN Bus exploit) to forge "Key Validated" commands, bypassing security verification.	**HIGH**
R-05	Public Cloud Asset Misconfiguration due to human administrative tracking error.	Enterprise IT --> Public-Facing Cloud Infrastructure	Insider (Systems Administrator)	Exposed database settings leaking over 2 million vehicle entries, including unique VIN sequences and terminal logs.	**MODERATE**

4. Architecture-Specific Control Strategy

This section establishes the engineering strategies used to prove how our system architecture supports and enforces our security controls. Drawn directly from NIST SP 800-53 Rev. 5, these

strategies translate compliance benchmarks into concrete, technical defenses within the TMMK environment. Rather than applying generic security guidelines, these controls are tailored to match our risk profile. By implementing these specific configurations, the architecture ensures a robust cybersecurity network.

Information Flow Enforcement (AC-4):

Strategy: Enforcement is accomplished through a segmented layout, with whitelist access control lists at each boundary, spanning the network layers [Enterprise IT → OT DMZ → Ops VLAN → Control VLAN → Floor VLAN]. (TMMK, 2023, pp. 4-5)

Information flow amid network layers is controlled by architectural mechanisms, including firewalls, proxies, and secure tunneling, which are deployed at each transition point. Instead of permitting unrestricted routing, the architecture regulates data transfers through these defined mechanisms.

Firewalls enforce explicit policy rules that require traffic moving between domains, from the Enterprise IT layer to Industrial layers, to traverse designated communication paths. To minimize the attack surface, the architecture mandates limited traversal through the DMZ using highly restrictive Access Control Lists (ACLs) and explicit whitelists. This design separation ensures that all cross-zone traffic is strictly monitored, heavily restricted, and validated against approved engineering parameters.

All of the systems will be hardened by disabling unused ports and unused services. This supports the least functionality and least sharing principles of NIST 800-160.

Software, Firmware, and Information Integrity (SI-7):

Strategy: Enforcement is accomplished through a sign-at-source, verify-at-boot chain of trust anchored in the air-gapped R&D enclave and the vehicle's onboard Trusted Platform Module (TPM).

All SafetySense 2.0 software packages are cryptographically signed within the physically isolated R&D environment before leaving the enclave, in accordance with the architectural requirement that code be manually uploaded to the trusted software delivery server via approved, monitored, and encrypted storage devices used exclusively for this purpose (TMMK, 2023, P. 9). The upload process requires dual authorization: only designated Senior R&D Engineers may perform uploads, and each upload event must be independently approved by the Security Officer using a dedicated approval console. Approval records are automatically logged and time stamped in the deployment audit system, which issues alerts to InfoSec for any unapproved or anomalous activity. Upload terminals are continuously monitored through both physical surveillance and endpoint security tools to detect unauthorized media use or improper access attempts. The cryptographic signature, not the transport medium, serves as the primary integrity control; the encrypted storage device protects confidentiality in transit.

Upon arrival at the software delivery server, the package is entered into a version-controlled software registry with an immutable changelog, permitting immediate detection of any deviation between a package and its registered signed hash (TMMK, 2023, p. 13). During installation, the vehicle's lightweight TPM functions as the architectural root of trust by authenticating the signature and hash of the incoming firmware against its stored trust anchor before permitting the

image to be flashed. The hypervisor layer verifies system integrity upon each boot up (TMMK, 2023, p. 10).

Firmware that fails signature or hash validation at either the software delivery server or the TPM is rejected prior to installation, thereby preventing any unsigned or tampered SafetySense 2.0 build from reaching a customer vehicle.

Supply Chain Risk Management Vetting (SR-6)

Strategy: Enforcement is achieved through continuous, automated, read-only auditing of Just-in-Time (JIT) vendor data flows, combined with physical hardware verification at the point of receipt.

Vendor and supplier data (inventory levels, parts sequencing, EDI feeds) are shared with the AGV and manufacturing DCS systems in a strictly read-only format (TMMK, 2023, p.5). This design constraint prevents a compromised or ransomware-encrypted vendor system from writing malicious commands into the plant's control systems, thereby directly lessening the R-01 JIT Supply-Chain Infrastructure Freeze scenario.

This unidirectional trust boundary is supplemented by continuous automated monitoring of vendor EDI traffic for anomalies, including unexpected volume drops, malformed transactions, or communication timeouts indicative of a ransomware event. Such irregularities trigger an automatic failover to a buffered parts-sequencing dataset, avoiding a full production halt. Anomaly detection runs on the Splunk SIEM platform, which ingests and correlates real-time EDI log data, alongside custom detection scripts that flag irregular transaction trends or timing anomalies specific to the JIT process. Integration with the existing SIEM ecosystem forwards incident alerts directly to InfoSec operations, guaranteeing swift escalation and response.

Conducting periodic reviews of processes and information-sharing practices, providing cybersecurity training to third-party suppliers, and implementing strong encryption and secure VPN connections will help mitigate the risk of a supply-chain compromise affecting plant operations.

On the physical side, each incoming component is scanned into the inventory management system before storage, and statistically sampled batches are diverted to Quality Assurance for deeper security inspection prior to release to the production line (TMMK 2023, p.5). Vendor risk scores derived from this continuous assessment process directly inform procurement decisions and are reassessed on a defined schedule consistent with SP 800-161 SCRM planning, rather than being treated as a one-time vetting event.

Incident Response Feedback Loop (IR-4):

Strategy: Enforcement is accomplished through automated, unit-level quarantine that isolates the affected vehicle and its immediate network segment without interrupting the full production line.

When the Final QA hash comparison against the vehicle database detects a mismatch, the affected unit is automatically flagged and physically diverted from the main assembly path into a quarantine station. The containment scope is intentionally limited to that single unit and its local network drop, rather than the entire Floor VLAN, therefore preserving the Just-in-Time line's zero-downtime tolerance.

Simultaneously, the system generates an incident ticket and freezes read/write access to the software delivery server segment associated with the affected unit's build, preventing further Over-The-Air pushes until the source of the mismatch is identified. Forensic data, including the TPM's boot and verification log, the software registry's immutable changelog, and the authentic signed-package hash, are collected to determine whether the mismatch originated in transit, at the TPM, or upstream in the R&D signing procedure.

From initial detection at Final QA to full containment and securing of related systems, the response process is typically completed within 10 to 15 minutes under normal operating conditions. The automated workflow and predefined escalation routes enable most mismatches to be detected and contained before additional impact occurs, allowing incident investigation and remediation to begin promptly.

The Quality Assurance & Calibration Specialist and Systems Security Engineer are notified per the RACI matrix, and the unit is held until it is reflashed from a known-good signed image and re-verified against the clean baseline hash. Simultaneously, incident details are integrated into the broader Security Operations Center (SOC) workflow: notifications are pushed directly to the enterprise incident management system, triggering aligned playbooks and guaranteeing full visibility for enterprise SOC analysts. This integration permits related teams to coordinate responses or adapt their processes as needed based on event severity or recurring trends. Findings are then fed back into the M-2 continuous monitoring rule set so the same failure mode is detected earlier in future builds, closing the IR-4 feedback loop.

4.1 Architecture-Applicable Risk Management Framework Tasks

This section documents the specific tasks within the NIST Risk Management Framework (RMF) lifecycle. Tailored from NIST SP 800-37 Rev.2, these task bridge compliance with practical defenses. Executing these steps ensures that security is built into every system boundary.

Risk Assessment - Cyber-Physical Impact Mapping (Task P-14 – page 60):

This task requires a system-level assessment to identify, prioritize, and document risks associated with system operation and use. For the TMMK cyber-physical architecture, threat vectors are mapped to their corresponding physical consequences. The assessment evaluates how vulnerabilities inside digital boundaries can directly affect physical operations, vehicle safety, and the safety of personnel on the manufacturing floor as well as vehicle owners and operators. Specific threat scenarios include industrial protocol spoofing, such as falsified Modbus/TCP commands that alter PLC behavior, unauthorized remote access attempts using stolen IT credentials, and insider misuse where maintenance engineers intentionally or inadvertently override safety interlocks through insecure HMIs. Additional scenarios may involve manipulation of CAN bus messaging or the supply chain delivery of pre-compromised programmable logic. The risk assessment document establishes operational risk thresholds, identifies threat sources targeting industrial control protocols, and provides baseline metrics necessary to justify tailored security controls from the ground up.

Security Control Selection - Perimeter Insulation (Task S-1 – page 69):

This task establishes the initial control baseline required to protect the system in accordance with its MODERATE-impact categorization. For the TMMK architecture, Perimeter Insulation

represents a customized approach that focuses on boundary and information-flow controls (AC-4, SC-7) at each Purdue Model transition point: from Enterprise IT to OT DMZ, OT DMZ to Ops VLAN, Ops VLAN to Control VLAN, and Control VLAN to Floor VLAN. This approach is favored over applying a uniform control set across the entire system. Each layer boundary acts as an independent insulating barrier, ensuring that a compromise at one boundary is contained and does not propagate to the Floor VLAN, where PLCs and DCS components operate.

Implementation at each boundary requires the following steps:

1. **For AC-4 (Information Flow Enforcement):** Define and enforce explicit rules for permitted communication directions and protocols between VLANs, utilizing firewalls and access control lists customized to the threat profile of each layer. Log and monitor all exceptions to these rules to quickly detect attempts to bypass established policies.
2. **For SC-7 (Boundary Protection)**: Deploy dedicated filtering devices, such as industrial firewalls or DMZ proxies, at each transition point. Configure device rules to block unauthorized services and ports, restrict lateral movement, and enable protocol-specific inspection appropriate for industrial traffic, such as blocking unauthenticated Modbus commands at the Control VLAN boundary.

For each implementation, document the control configuration, review it against the threat scenarios identified in the risk assessment, and adjust as necessary based on operational requirements and the risk tolerance specific to that layer.

This selection directly supports the mitigation of R-02 (Air-Gap Tampering) and R-03 (Unauthenticated PLC Logic Manipulation) by ensuring each layer inherits controls tailored to its specific threat exposure, rather than relying on a generic enterprise baseline.

Remediation of Vulnerabilities at the Boundary (Task I-2 – page 77):

This task documents the current, as-implemented state of controls and updates the security plan whenever a planned control implementation changes. For TMMK, remediation activities are architecturally scoped to boundary-enforcement devices, such as firewalls, DMZ proxies, and ACL allowlists, rather than to endpoint systems. When a vulnerability or rule gap is identified at a transition point, such as an overly permissive ACL discovered during the R-04 CAN Bus review, the remediation is tested in a staging environment, documented with updated expected inputs, behavior, and outputs, and then deployed to the boundary device during a scheduled maintenance window to avoid interruption of Just-in-Time production. Maintenance windows are coordinated in advance with operations teams and scheduled during periods of minimal plant activity to ensure rollback options are available if deployment issues arise. Prior to each update, a rollback plan is documented, including backups of pre-change configurations and clear restoration steps. This process enables remediation activities to be planned with minimal operational risk and ensures the security plan's description of boundary controls stays synchronized with their actual configuration.

Security Monitoring - Industrial Anomaly Detection (Task M-2 – page 97):

This task evaluates the effectiveness of controls within the system's continuous monitoring strategy. For TMMK, this is achieved through OT-aware anomaly detection deployed at the Control VLAN and Floor VLAN boundaries. Normal Modbus and PROFINET traffic patterns are baselined so that deviations, such as unauthenticated write commands to a PLC (R-03) or unexpected CAN bus traffic from an exterior harness splice (R-04), are identified in near real time

rather than only during periodic audits. Common industrial anomaly detection platforms include Nozomi Guardian, Claroty Continuous Threat Detection, and Cisco Cyber Vision, all of which support ICS protocol inspection and integrate with existing SIEM and incident response platforms. Alerts generated by these systems feed directly into the IR-4 incident response feedback loop, and lessons learned from previous hash-mismatch containment events are used to improve detection thresholds over time.

5. Roles and Responsibilities

Securing the converged IT/OT ecosystem requires a collaborative approach divided among four specialized roles. To execute this assessment efficiently, the team relies on a cross-functional breakdown of four core engineering roles:

- Systems Security Engineer: (Mukwaya Lwere) Leads the overarching RMF lifecycle process and authors the final System Security Plan (SSP). Selects the baseline NIST SP 800-53 controls and policies to mitigate third-party Just-in-Time (JIT) supplier vulnerabilities.
- OT Network & Systems Engineer: (Samuel Yoon) Manages the physical and logical configuration of the plant network environment. Configures the segmented Purdue Model hierarchy and deploys whitelist-based Access Control Lists (ACLs) on internal firewalls to isolate unauthenticated Modbus and PROFINET protocols.
- Legal & Standards Consultant: (Desiree O'Cleireachain) Ensures the entire engineering lifecycle complies with governing standards and automotive safety rules. This role is responsible for verifying that cybersecurity controls protect customer privacy, reduce manufacturer liability, and meet all federal critical manufacturing guidelines.
- Quality Assurance & Calibration Specialist: (Bhanu K) Operates the end-of-line vehicle validation testing stations. Verifies the vehicle's Trusted Platform Module (TPM) configurations, confirms Secure Boot integrity, and executes the automated containment and rollback response if a final firmware hash mismatch occurs.

6. RACI Accountability Matrix

RMF Phase / Identified Risk Surface	Systems Security Engineer	OT Network & Systems Engineer	Legal & Standards Consultant	Quality Assurance & Calibration Specialist
Phase 1: Prepare and Categorize	A	R	C	I
Phase 2: Control Selection	A	C	R	I
Phase 3: Implementation	A	R	I	R
Phase 4: Assessment	A	I	C	R
Phase 5: Authorization	A	I	R	I
Phase 6: Continuous Monitoring	A	R	I	C
R-01 JIT Supply-Chain Infrastructure Freeze	A	R	C	I

RMF Phase / Identified Risk Surface	Systems Security Engineer	OT Network & Systems Engineer	Legal & Standards Consultant	Quality Assurance & Calibration Specialist
R-02 Air-Gap Ingest Tampering & Stuxnet-Style Payload Lateralization	A	R	C	I
R-03 Unauthenticated PLC Logic Manipulation	C	A	I	R
R-04 CAN Bus Layer Exploitation	C	I	I	A/R
R-05 Public Cloud Asset Misconfiguration	A/R	C	C	I

Key Definitions:

- **R (Responsible):** The role that physically executes the technical task
- **A (Accountable):** The role with final approval power and ultimate ownership over the phase or risk defense.
- **C (Consulted):** The role that provides specialized expert input, constraints, or guidance before an action is taken.
- **I (Informed):** The role that is kept updated on progress, outcomes, or automated incident alerts.

7. RMF Foundations for SSP

This table shows which specific sections and/or phases of the Risk Management Framework (RMF) foundation for corresponding sections of the System Security Plan (SSP):

RMF Phase/Section	Provides Foundation For	Corresponding SSP Section
Section 1 Security Categorization & Impact Matrix	Defines the security category and potential impact	Section 3 System Categorization
Phase 1: Prepare & Categorize	Identifies the system and subsystem. Defines baseline security classification Defines the authorization scope, business dependencies, and baseline security classification.	Section 2: System Name/Title Section 3: System Categorization Section 9: General Description/Purpose Section 12: System Interconnections
Phase 2: Control Selection	Describing the system interfaces and interconnections. Assigns specific NIST controls.	Section 12: System Interconnections Section 13: Security Controls
Phase 3: Implementation	Documenting the physical and technical system environment	Section 11: System Environment
Phase 4: Assessment	Discussing assessment findings, including any evaluation data, and any system defects.	Section 1: Executive Summary

RMF Phase/Section	Provides Foundation For	Corresponding SSP Section
Phase 5: Authorization	Outlines operational thresholds, authorization signatures, and restrictions.	Section 5: Authorizing Official Section 6: Organization Structure
Phase 6: Continuous Monitor	Details automated scanning configurations, parameters and rules.	Section 16: Appendix
Section 3: Threat Modeling & Cyber-Physical Risk Register	Discussing findings and potential impact	Section 3: System Categorization
Section 4: Architecture	Defining specific NIST controls.	Section 13: Security Controls
Section 5: Roles and Responsibilities	Identifying point of contact, and authorizing official by title and responsibilities	Section 4: System Owner Section 5: Authorizing Official
Section 6: RACI Accountability Matrix	Identifying point of contact, and authorizing official by title and responsibilities	Section 4: System Owner Section 5: Authorizing Official

References

International Organization for Standardization. (2018). Road vehicles — Functional safety — Part 6: Product development at the software level (ISO Standard No. 26262-6:2018). https://www.iso.org/obp/ui/#iso:std:iso:26262:-6:ed-2:v1:en

National Institute of Standards and Technology. (2004). Standards for security categorization of federal information and information systems (Federal Information Processing Standards Publication 199). U.S. Department of Commerce. https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.199.pdf

National Institute of Standards and Technology. (2018). Risk management framework for information systems and organizations: A system life cycle approach for security and privacy (NIST Special Publication 800-37, Revision 2). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-37r2

National Institute of Standards and Technology. (2020). Security and privacy controls for information systems and organizations (NIST Special Publication 800-53, Revision 5). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-53r5